

MSc Cyber Security-2025/26

CYBER RISK ASSESSMENT

CMP-LO19-0

Contents

1	Part 1: Security Risk Review of DVWA	5
1.1	Task-1: Identification of Assets	5
1.2	Taks-2: Qualitative Analysis.	8
1.3	Task-3: Quantitative Analysis.	8
1.4	Task-4: Reflection on Both methods of Analysis.	10
2	Part-2: Threat Analysis for the OSA Age Verification Process	11
2.1	Task-1: Identifying System Components and Actors.	11
2.2	Task-2: DFD Diagram, showing Trust Boundaries.	12
2.3	Task-3: Applying STRIDE framework.....	13
2.4	Task-4: Reflection (for all Trust Boundaries).....	21
3	Part-3: Vulnerability Rating and System Resilience	22
3.1	Task-1: Vulnerability Discovery	22
3.2	Task-2: Verification and Mapping.....	23
3.3	Task-3: CVSS Scoring.....	28
3.4	Task-4: KEV Prioritization.....	33
3.5	Task-5: Resilience and Redundancy(Ross <i>et al.</i> , 2021).	35
	References	36

TABLES

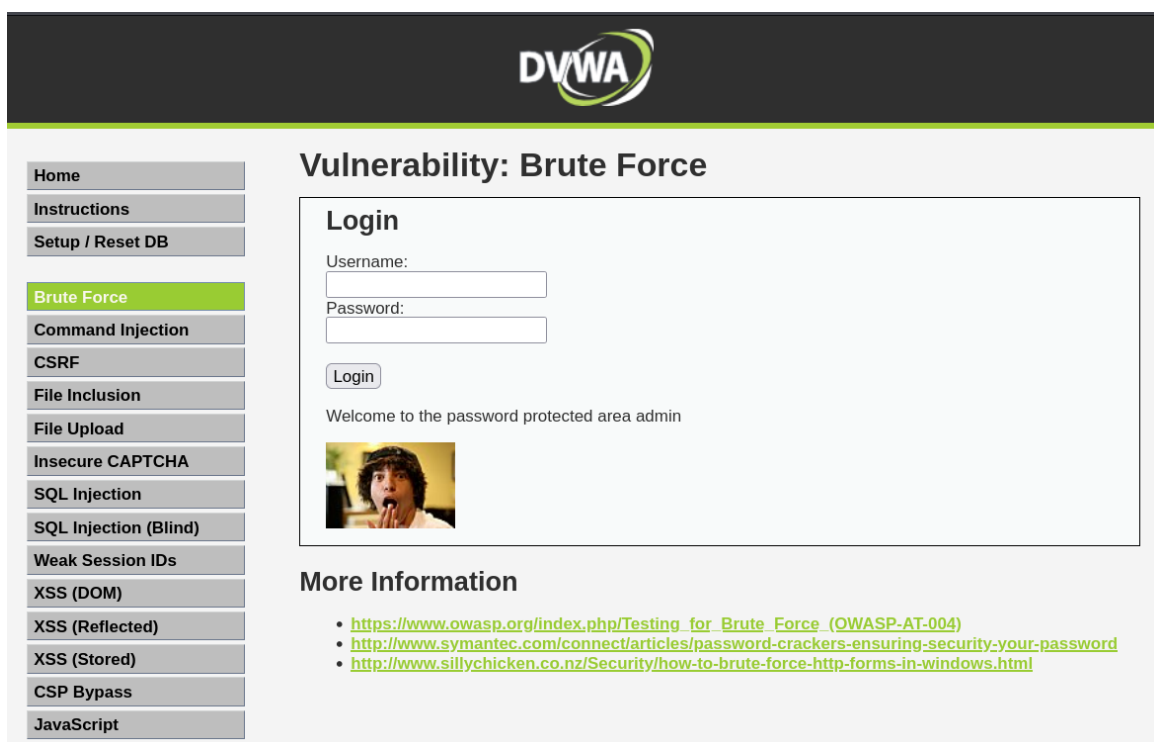
Table 1: IDENTIFIED ASSESTS FROM DVWA(dvwa Kali Linux Tools, June 2025).	7
Table 2: risk description.....	8
Table 3: Risk description.....	10
Table 4: trust boundary 1 (user/external component)	13
Table 5: TRUST BOUNDARY 1 (website platform)	14
Table 6: VULnerability description for tb1.	14
Table 7: TRUST BOUNDARY 2 (WEBSITE PLATFORM).....	15
Table 8: trust boundary 2(Platform backend server)	15
Table 9: Vulnerability description for tb2.....	16
Table 10: TRUST BOUNDARY 3 (Platform backend server)	16
Table 11: TRUST boundary 3: avp api.....	17
Table 12: vulnerability description for tb3.	17
Table 13: trust boundary 4 (Platform backend server)	18
Table 14: trust boundary 4 (compliance logs).....	18
Table 15: vulnerability description for tb4.	19
Table 16: REcommendation and mitigation for all vulnerabilities.	20
Table 17: Description of the vulnerabilities from the nessus scans (<i>Common Vulnerabilities and Exposures (CVEs) / Tenable®</i> , no date).....	23
Table 18: Description of weaknesses using cwe.mitre.org(<i>CWE - Common Weakness Enumeration</i> , no date)	24
Table 19: CVSS version 4 base metric scoring(<i>Common Vulnerability Scoring System Version 4.0 Calculator</i> , no date).	28
Table 20: CVE-2025-62171 SCORE COMPARISON.	32
Table 21: CVE-2025-58767 SCORE COMPARISON.	32
Table 22: CVE-2025-61984 SCORE COMPARISON.	33
Table 23: KEV prioritization table.	33
Table 24: Vulnerability prioritization table.....	34

FIGURES

Figure 1: USER LOGGING PAGE	5
Figure 2: File upload function.....	6
Figure 3: TEST PAGE FOR SQL INJECTION	6
Figure 4: SESSIONs ID PAGE.....	7
Figure 5: KEY SYSTEM COMPONENTS WITH DATA FLOWS.	12
Figure 6: DFD SHOWING SYSTEM TRUST BOUNDARIES.	12
Figure 7: aCTIVE SCAN ANALYSIS ON NESSUS.	22
Figure 8: NESSUS SCAN REPORT	22
Figure 9:cve-2025-62171 description.....	25
Figure 10: cwe-190 description.	25
Figure 11: cve-2025-58767 description.....	26
Figure 12: cwe-400 description	26
Figure 13: cve-2025-61984 description.....	27
Figure 14: cwe-159 description.	27
Figure 15: CVE-2025-62171 CVSS V4 SCORE.	29
Figure 16: CVE-2025-62171 NESSUS SCORE.....	29
Figure 17: CVE-2025-58767 CVSS V4 SCORE.	30
Figure 18: CVE-2025-58767 NESSUS SCORE.....	30
Figure 19: CVE-2025-61984 CVSS V4 SCORE.	31
Figure 20: CVE-2025-61984 NESSUS SCORE.....	31

1 | PART 1: SECURITY RISK REVIEW OF DVWA

1.1 | Task-1: Identification of Assets



DVWA

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

Vulnerability: Brute Force

Login

Username:

Password:

Login

Welcome to the password protected area admin



More Information

- [https://www.owasp.org/index.php/Testing_for_Brute_Force_\(OWASP-AT-004\)](https://www.owasp.org/index.php/Testing_for_Brute_Force_(OWASP-AT-004))
- <http://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password>
- <http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>

FIGURE 1: USER LOGGING PAGE

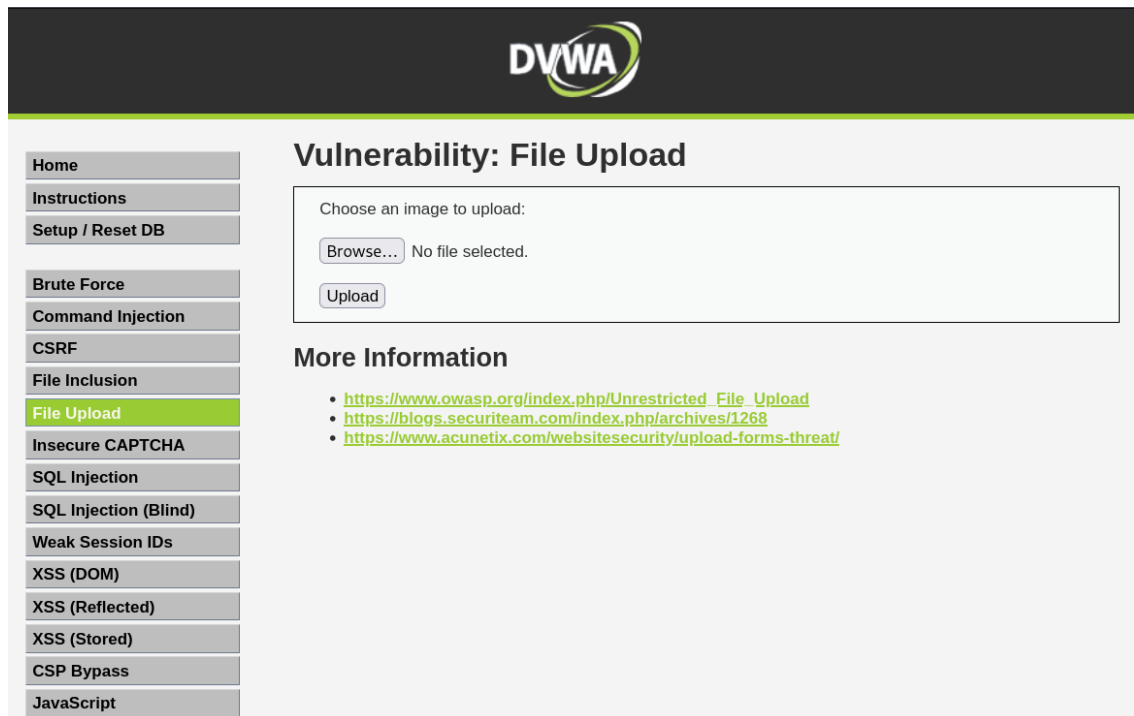


FIGURE 2: FILE UPLOAD FUNCTION.

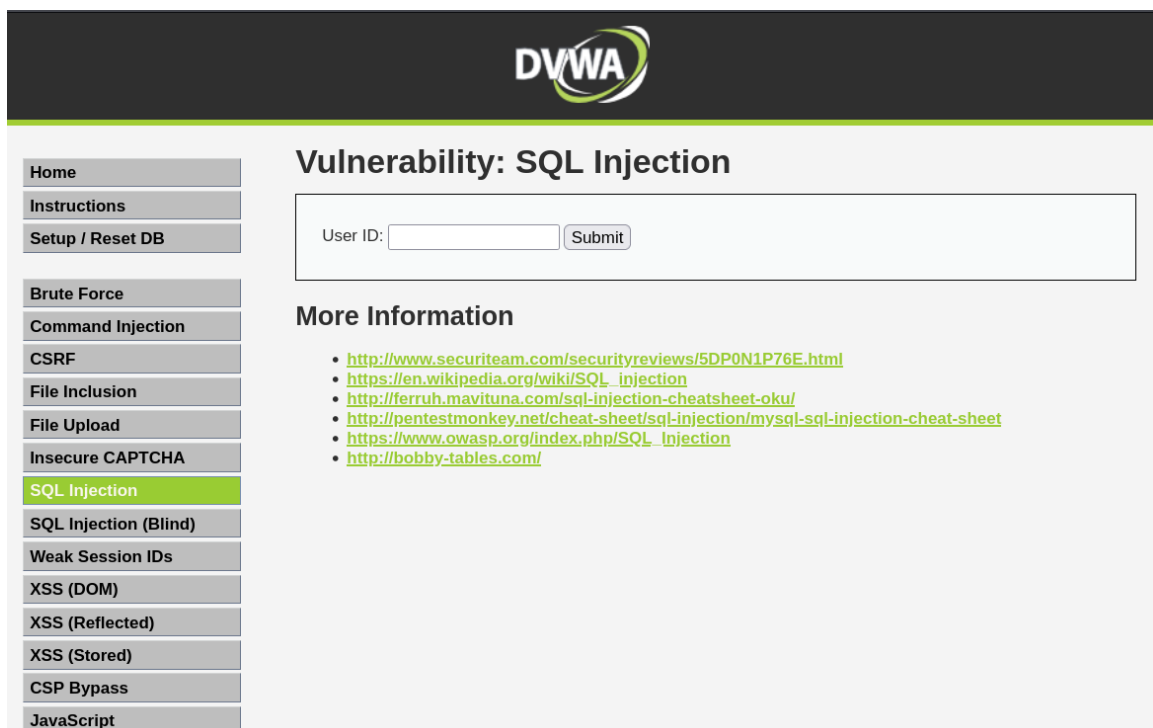


FIGURE 3: TEST PAGE FOR SQL INJECTION

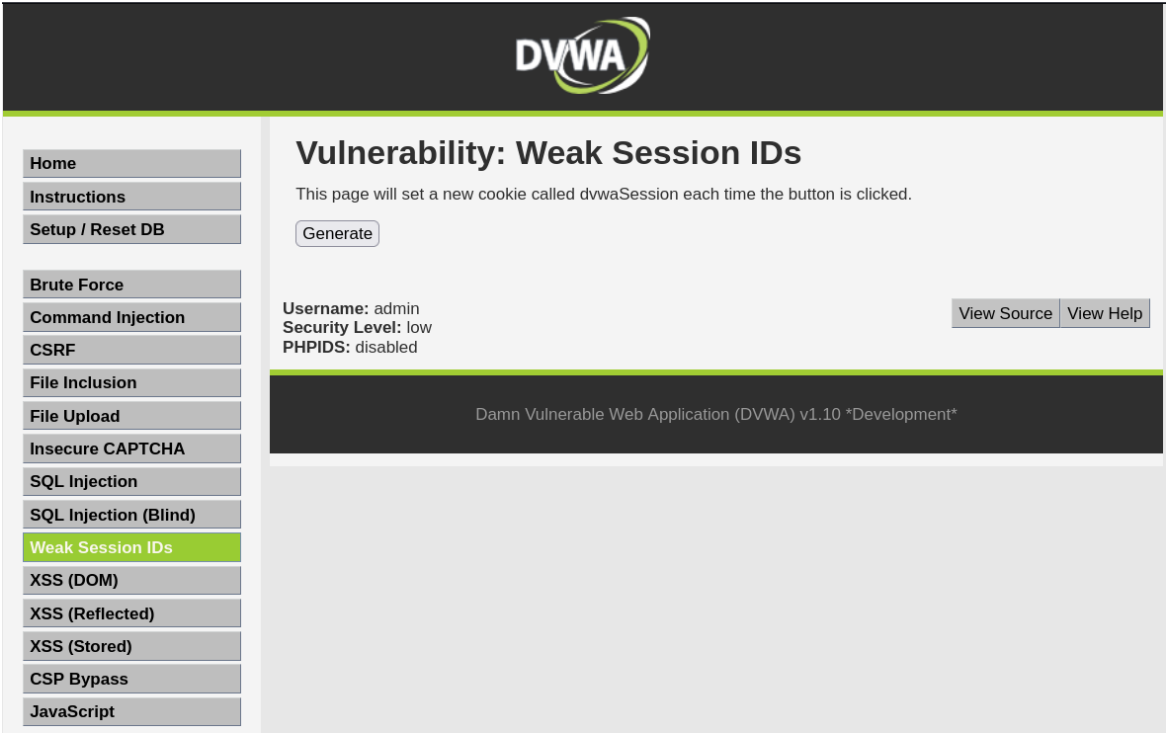


FIGURE 4: SESSIONS ID PAGE.

TABLE 1: IDENTIFIED ASSESTS FROM DVWA(DVWA | KALI LINUX TOOLS, JUNE 2025).

Asset Identified	Asset Type	Business Role
User Login and Authentication	Service	Controls access to the application, enables security boundaries by controlling access and verifying user identity.
User Data Records	Data (Database)	Stores and manages sensitive user information
File Upload Storage	Service/Infrastructure	Allows users to upload external files, which are stored on the server.
User Session Management	Service	Maintains user authentication state, after logging in, preventing continuous re-authentication.

1.2 | Taks-2: Qualitative Analysis.

$$R_{Qual} = I_{Qual} + P_{Qual}$$

TABLE 2: RISK DESCRIPTION.

Risk Description	P_{Qual}	I_{Qual}	R_{Qual} (Score)	Risk Level	Justification
User Data Records: SQL injection, database compromise	4	4	8	High	DVWA demonstrates how easy it is to extract or modify user data; threat actors can use widely available payloads to modify records or destroy databases. SQL injection is one of the most common web attacks.
File Upload Storage: Remote Code Execution and Uploading a Web shell	4	5	9	Extreme	DVWA's file uploads show how attackers can upload web shells; an attacker can also access all application files, install malware and have dangerous business implications.
User Session Management: Session Hijacking due to weak session IDs	3	4	7	High	Session tokens in DVWA, are weak and predictable. Attackers can impersonate users or admins to perform unauthorized actions, damaging user trust and integrity

1.3 | Task-3: Quantitative Analysis.

Qualitative Analysis Formulars:

- $P_{Quant} = N \cdot 10^{(P_{Qual}-5)}$
- $V_{Quant} = M \cdot 10^{(I_{Qual}-5)}$
- $R_{Quant} = P_{Quant} \cdot V_{Quant}$
- $N(BaselineFrequency) = 100$
- $M(MaximumImpact) = £30,000,000$

Qualitative Risk Analysis for User Data Records

$$P_{Qual} = 4 \quad I_{Qual} = 4$$

$$P_{Quant} = 100 \cdot 10^{(4-5)}$$

$$P_{Quant} = 100 \cdot 01$$

$$P_{Quant} = 10 \text{ events per year}$$

$$V_{Quant} = £30,000,000 \cdot 10^{(4-5)}$$

$$V_{Quant} = £3,000,000$$

$$R_{Quant} = 10 \cdot £3,000,000$$

$$R_{Quant} = £30,000,000$$

Quantitative Analysis for file upload storage

$$P_{Qual} = 4 \quad I_{Qual} = 5$$

$$P_{Quant} = 100 \cdot 10^{(4-5)}$$

$$P_{Quant} = 10 \text{ events per year}$$

$$V_{Quant} = £10,000,000 \cdot 10^{(5-5)}$$

$$V_{Quant} = £10,000,000$$

$$R_{Quant} = 10 \cdot £10,000,000$$

$$R_{Quant} = £300,000,000$$

Quantitative Analysis for User Session Management

$$P_{Qual} = 3 \quad I_{Qual} = 4$$

$$P_{Quant} = 100 \cdot 10^{(3-5)}$$

$$P_{Quant} = 1 \text{ events per year}$$

$$V_{Quant} = £10,000,000 \cdot 10^{(4-5)}$$

$$V_{Quant} = £3,000,000$$

$$R_{Quant} = £3,000,000 \cdot 1$$

$$R_{Quant} = £3,000,000$$

Justification:

Using $N = 100$ gives a wide and detailed scale for measuring how likely a risk is, allowing you to rate events with much better precision than a smaller scale. Setting $M = £30,000,000$ as the maximum impact creates room to capture serious financial or operational damage without exaggerating the numbers. This combination makes the model flexible, realistic, and capable of handling both small-scale and high-impact risks in a balanced way.

TABLE 3: RISK DESCRIPTION.

Risk Description	P_{Qual}	I_{Qual}	P_{Quant} Events/year	V_{Quant} (£)	R_{Quant} £
User Data Records: SQL injection, database compromise	4	4	10	£3,000,000	£30,000,000
File Upload Storage: Remote Code Execution and Uploading a Web shell	4	5	10	£30,000,000	£300,000,000
Weak Session IDs Session Hijacking	3	4	1	£3,000,000	£3,000,000

1.4 | Task-4: Reflection on Both methods of Analysis.

1. Reflection on the analysis:

Both the qualitative and quantitative results show the same order of risk. In the qualitative ranking, the File Upload Storage issue (Remote Code Execution and web shell uploads) scored highest with a 9, placing it in the Extreme category. The quantitative ranking supports this, showing it could happen about ten times a year with a possible loss of £30,000,000. SQL Injection ranked second, and Session Management ranked third across both methods.

2. Comparing the rankings:

Qualitatively, the risks appear close (scores 9, 8, and 7), which helps with quick prioritisation but doesn't show how different the real impacts are. The quantitative results reveal these gaps clearly: the highest risk is 10 times bigger than the second and 100 times bigger than the lowest. This provides a more realistic view of how much damage each risk could cause.

3. Which method is more useful?

In this scenario, the quantitative method offers far more value. While qualitative ratings help communicate risk levels, showing a stakeholder that a risk could cost £30,000,000 per year is much more convincing. Quantitative analysis exposes the real financial impact and supports stronger budgeting and security planning.

4. Recommended prioritisation and treatments Using both analyses, the File Upload Storage risk should be addressed first, followed by SQL Injection, and then Session Hijacking.

- **File Upload Storage:** The best treatment is Reduce. Controls such as ISO 27002:2022-8.12 (Data Leakage Prevention) and ISO 27002:2022-8.28 (disabling execution of uploaded files) help prevent data leaks and block dangerous uploads. This risk is too serious to transfer because it could lead to severe data loss or business shutdown.
- **SQL Injection:** This should also be Reduced by applying secure coding controls under ISO 27002:2022-8.28, such as parameterised queries and strict input validation.
- **Session Hijacking:** Although cheaper to fix, it remains important. It should also be Reduced using controls from ISO 27001:2022-5.15, including secure session tokens (HTTPS-only), regenerating session IDs, and shortening session durations.

2 | PART-2: THREAT ANALYSIS FOR THE OSA AGE VERIFICATION PROCESS

2.1 | Task-1: Identifying System Components and Actors.

Components:

- **The Website:** the web UI platform in which the user interacts.
- **The Platforms Server:** The web platforms backend server that stores evidence, the user's ID in the form of a selfie. Manages the access control logic and enables effective communication with the AVP.
- **AVPs API:** The API used for age verification receives the user ID and returns the result after verification.
- **Compliance Logs:** Secured data stored within the platform that provides evidence of compliance, timestamps of the Ofcom requests.

Actors:

- **Users:** Person child or adult requesting restricted data
- **Age Verification Provider:** the third-party service that checks ID
- **Internal Admins/SIEM:** internal staff that can monitor logs
- **Ofcom:** regulator / auditor (may request evidence).

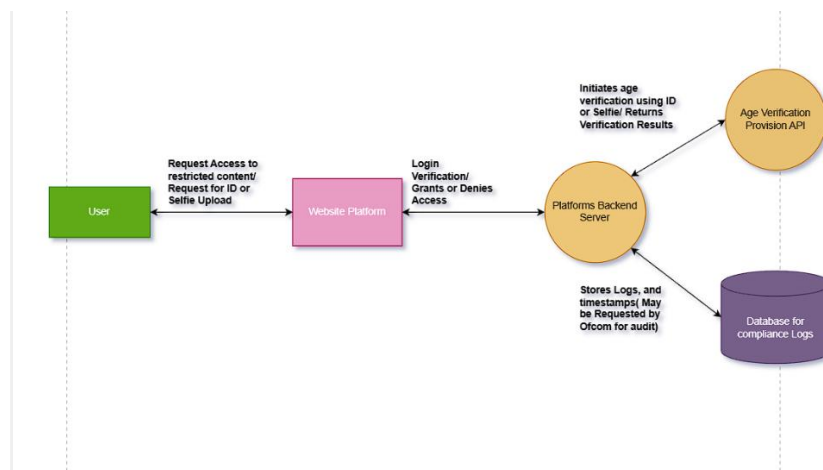


FIGURE 5: KEY SYSTEM COMPONENTS WITH DATA FLOWS.

2.2 | Task-2: DFD Diagram, showing Trust Boundaries.

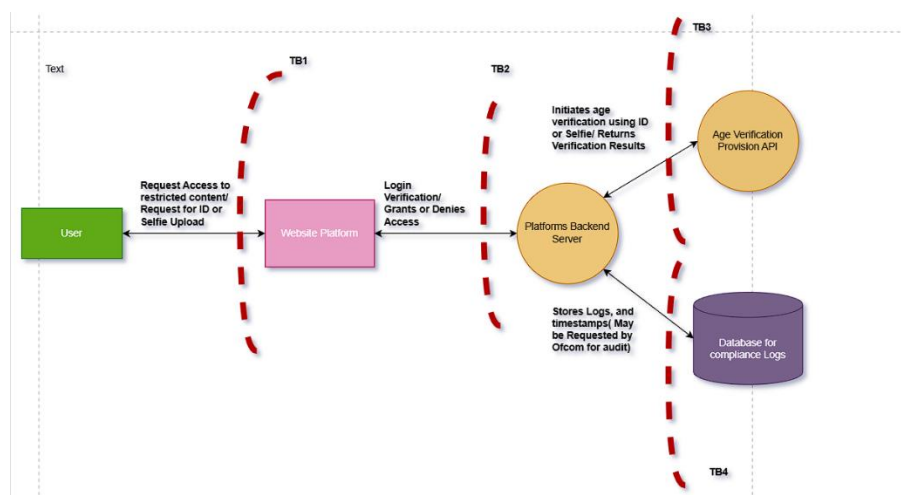


FIGURE 6: DFD SHOWING SYSTEM TRUST BOUNDARIES.

1. Trust Boundary 1 (TB1):

This Boundary is the user and the website Platform. This is where external users interact with the platform's services. The user is an untrusted entity; they could be a legitimate adult or a minor. The platform can't trust a user's identity without proper authentication authorization.

2. Trust Boundary 2 (TB2):

This boundary is the Website Platform and the Platform Backend Server. The Website Platform then sends the request (with the user's ID and selfie) to the Backend Server

3. Trust Boundary 3 (TB3):

This Boundary is between the Platforms Backend Server and the Age Verification Provider (AVP) API. The platform assigns a critical security function (age verification) to an external provider. The platform must authenticate the AVP and protect the integrity and confidentiality of the user's data being exchanged.

4. Trust Boundary 4 (TB4):

This Boundary is focused between the Platform Backend Server (and other internal systems) and the secure database storing compliance evidence. This boundary is designed to protect the confidentiality, integrity and availability of audit trails. The compliance logs are highly targeted because it contains the evidence of regulations being followed or not (Shostack, 2024).

2.3 | Task-3: Applying STRIDE framework.

TABLE 4: TRUST BOUNDARY 1 (USER/EXTERNAL COMPONENT)

TB1	Users	
	Strength	Weaknesses
Spoofing		V1: Using fake/deepfake ID
Tampering		
Repudiation	Action can be tied to device IP address.	
Information disclosure		V2: May unknowingly share sensitive Data in selfie (User Behaviour)
Denial of service		
Elevation of privilege	Users have minimal privileges.	

TABLE 5: TRUST BOUNDARY 1 (WEBSITE PLATFORM)

TB1	Website Platform	
	Strength	Weaknesses
Spoofing		V3: website can be spoofed using a phishing site.
Tampering		
Repudiation		
Information disclosure	Enforces HTTPS, protecting sensitive data.	
Denial of service		
Elevation of privilege		

TABLE 6: VULNERABILITY DESCRIPTION FOR TB1.

Vuln ID	Description	Examples
V1	Use fake/deepfake IDs	Users can use AI to bypass security checks that require proof of identity (e.g. bypassing “liveness check”)
V2	May unknowingly share sensitive Data in selfie (User Behaviour)	Attackers can zoom in on the selfies to extract data, that allows them to steal identities or hack corporate network (e.g ID card barcode, employee ID number)
V3	website can be spoofed using a phishing site.	Attacks can create a fake website that looks identical to the legitimate one, to trick users into entering personal data (e.g tricking users with different spellings of the site, apple.com and apple.com)

TABLE 7: TRUST BOUNDARY 2 (WEBSITE PLATFORM)

TB2	Website Platform	
	Strength	Weaknesses
Spoofing		
Tampering		
Repudiation		
Information disclosure		
Denial of service		V4: Backend connections can be exhausted
Elevation of privilege		

TABLE 8: TRUST BOUNDARY 2(PLATFORM BACKEND SERVER)

TB2	Platform Backend Server	
	Strength	Weaknesses
Spoofing	Proper authentication of website using API keys	
Tampering		
Repudiation		
Information disclosure		
Denial of service		
Elevation of privilege		V5: Bugs in the backend can enable access to AVP functions

TABLE 9: VULNERABILITY DESCRIPTION FOR TB2.

Vuln ID	Description	Examples
V4	Backend connections can be exhausted	Attackers can flood the server with fake or malicious requests (e.g HTTP floods that overwhelms servers and backend DB calls.
V5	Bugs in the backend can enable access to AVP functions	Flaws in the backend could enable attackers to gain access to admin privileges (an example of such bug is incorrect role validation.

TABLE 10: TRUST BOUNDARY 3 (PLATFORM BACKEND SERVER)

TB3	Platform Backend Server	
	Strength	Weaknesses
Spoofing	Uses API tokens/keys	
Tampering		
Repudiation		
Information disclosure		
Denial of service		
Elevation of privilege		

TABLE 11: TRUST BOUNDARY 3: AVP API

TB3	AVP API	
	Strength	Weaknesses
Spoofing		
Tampering		V6: Altering API responses.
Repudiation		
Information disclosure		
Denial of service		V7: Single Point of failure
Elevation of privilege		

TABLE 12: VULNERABILITY DESCRIPTION FOR TB3.

Vuln ID	Description	Examples
V6	Altering API responses	AVP systems could be modified to always return "over18=true", ensuring even underaged to get access.
V7	Single Point of failure	Attackers can launch an attack that can cause service outage, ensuring all age verification stops working

TABLE 13: TRUST BOUNDARY 4 (PLATFORM BACKEND SERVER)

TB4	Platform Backend Server	
	Strength	Weaknesses
Spoofing		
Tampering		V8: Possible SQL injection
Repudiation		
Information disclosure		
Denial of service		
Elevation of privilege		

TABLE 14: TRUST BOUNDARY 4 (COMPLIANCE LOGS)

TB4	Compliance Logs	
	Strength	Weaknesses
Spoofing		
Tampering		
Repudiation		V9: Lost Logs
Information disclosure		
Denial of service		V7: Single Point of failure
Elevation of privilege	Role based Access	

TABLE 15: VULNERABILITY DESCRIPTION FOR TB4.

Vuln ID	Description	Examples
V7	Single Point of failure	DDoS attack floods the compliance logs system with massive traffic, making it unavailable for legitimate use for Ofcom audits.
V8	Possible SQL injection	Attackers can inject SQL, leading to compromise of the database.
V9	Lost Logs	No evidence of user actions, allowing repudiation. Attackers may delete verification records for certain periods.

TABLE 16: RECOMMEDATION AND MITIGATION FOR ALL VULNERABILITIES.

REC ID	Recommendations for Mitigation
REC1	Implementing active liveness detection with challenge-response tests (i.e. blinking, head movement) to prevent fake and deepfake ID submission.
REC2	Provide clear user guidance on selfie safety, automatically blur/cover sensitive background information.
REC3	Use browser security features like Use browser security features like HTTP Strict Transport Security (HSTS), and display visual trust indicators, so users can verify if the site is safe or not.
REC4	Use strong rate limits so too many requests can't overload the system and crash it. Connections should automatically close if it takes too long to respond.
REC5	Using detailed roles and rules to control backend services, giving only needed permissions, nothing more.
REC6	Make sure the AVP signs every API response using secure Hash-based Message Authentication Code alongside with SHA-256 algorithm. The platform would check the signature before trusting any verification results.
REC7	Use more than one age-verification provider so the system isn't dependent on a single system, if the main prover goes down, automatically switch to the backup.
REC8	Always use parameterized queries when working with the database so user input can't break or change queries, also use database firewalls, and conduct regular tests for SQL injection.
REC9	Ensuring Standard cryptographic proofs for audit trails

2.4 | Task-4: Reflection (for all Trust Boundaries)

The biggest dangers are spoofing at TB1 and Repudiation TB4 because they mostly threaten both user safety and legal compliance. Using Deepfakes or fake IDs let minors get past the age checks. This defeats the whole purpose of the online child safety act thereby exposing children to harmful content.

There can also be financial risks. Repudiation happens when the platform can't prove a user was verified. Without signed evidence of authorized use, the platform can fail on Ofcom audits even if most of the operations were done correctly. This risks huge fines (up to 10% of global revenue) and possible service restrictions.

Because the system depends on third-party age verification provider, any failure, fake AVP responses or missing verification records, violates the entire compliance process. This should be treated as top priorities because the users and the website platform are at serious risk(Shostack, 2014).

3 | PART-3: VULNERABILITY RATING AND SYSTEM RESILIENCE

3.1 | Task-1: Vulnerability Discovery

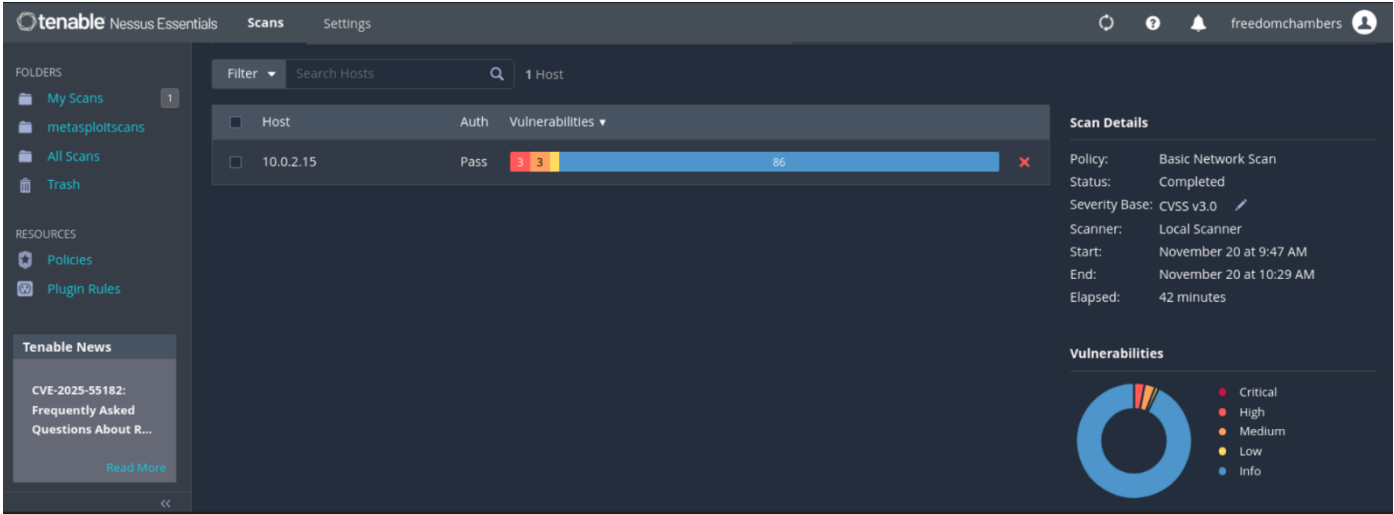


FIGURE 7: ACTIVE SCAN ANALYSIS ON NESSUS.

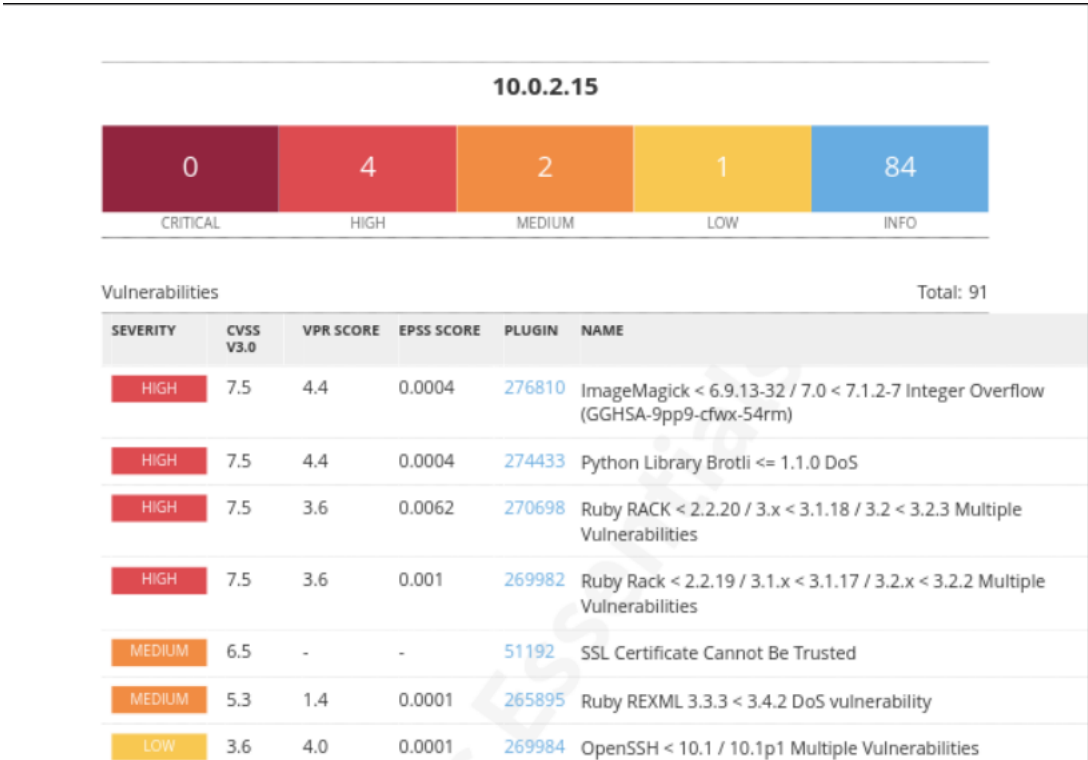


FIGURE 8: NESSUS SCAN REPORT

3.2 | Task-2: Verification and Mapping

TABLE 17: DESCRIPTION OF THE VULNERABILITIES FROM THE NESSUS SCANS (COMMON VULNERABILITIES AND EXPOSURES (CVES) / TENABLE®, NO DATE).

CVE	CVE Description	CRITICALITY	CVE (Root Cause)
CVE-2025-62171 (ImageMagick BMP Integer Overflow 32-bit)	On 32-bit ImageMagick systems, processing certain BMP images can trigger an integer overflow, causing a crash or processing failure. Mostly affects older architectures.	High (7.5)	CWE-190
CVE-2025-58767 (REXML XML Parsing DoS)	The Ruby REXML library (v3.3.3–3.4.1) enters a denial-of-service loop when parsing XML files containing multiple XML declarations. Any system that processes untrusted XML can become unresponsive.	Medium (5.3)	CWE-400
CVE-2025-61984 (OpenSSH Control Character Injection)	OpenSSH (before v10.1) allows attackers to insert harmful control characters into usernames from untrusted sources. If a system uses ProxyCommand or similar, this can lead to unintended command execution.	Low(3.6)	CWE-159

TABLE 18: DESCRIPTION OF WEAKNESSES USING CWE.MITRE.ORG(CWE - COMMON WEAKNESS ENUMERATION, NO DATE)

CVE (Root Cause)	Description
CWE-190 : Integer Overflow or Wraparound	The system performs arithmetic that exceeds the size limit of the data type, causing values to wrap around and potentially leading to invalid or unsafe program states.
CWE-400 : Uncontrolled Resource Consumption	The application cannot properly manage finite resources. A specially crafted input can cause excessive CPU/memory use, slowing or breaking system availability.
CWE-159 : Improper Handling of Invalid Use of Special Elements	The software fails to correctly filter or process special characters in user-controlled input, which can alter program behavior and compromise integrity.

CVE

AboutPartner InformationProgram OrganizationDownloadsResources & Support

CVE-2025-62171

Search

Search tips

Provide feedback

Report/Request

CVE-2025-62171

PUBLISHED

View JSON

User Guide

Required CVE Record Information

CNA: GitHub (maintainer security advisories)

Published: 2025-10-17 Updated: 2025-10-17

Title: ImageMagick vulnerable to denial of service via integer overflow in BMP decoder on 32-bit systems

Description

ImageMagick is an open source software suite for displaying, converting, and editing raster image files. In ImageMagick versions prior to 7.1.2-7 and 6.9.13-32, an integer overflow vulnerability exists in the BMP decoder on 32-bit systems. The vulnerability occurs in coders/bmp.c when calculating the extent value by multiplying image columns by bits per pixel. On 32-bit systems with size_t of 4 bytes, a malicious BMP file with specific dimensions can cause this multiplication to overflow and wrap to zero. The overflow check added to address CVE-2025-57803 is placed after the overflow occurs, making it ineffective. A specially crafted 58-byte BMP file with width set to 536,870,912 and 32 bits per pixel can trigger this overflow, causing the bytes_per_line calculation to become zero. This vulnerability only affects 32-bit builds of ImageMagick where default resource limits for width, height, and area have been manually increased beyond their defaults. 64-bit systems with size_t of 8 bytes are not vulnerable, and systems using default ImageMagick resource limits are not vulnerable. The vulnerability is fixed in versions 7.1.2-7 and 6.9.13-32.

CWE 1 Total

Learn more

CWE-190: Integer Overflow or Wraparound

CVSS 1 Total

Learn more

Score	Severity	Version	Vector String
5.9	MEDIUM	3.1	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Product Status

On This Page

Required CVE Record Information

CNA: GitHub (Maintainer Security Advisories)

CVE Program

Authorized Data Publishers

CISA-ADP

FIGURE 9:CVE-2025-62171 DESCRIPTION

CWE

Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE?
Start here!

Home > CWE List > CWE-190: Integer Overflow or Wraparound (4.18)

ID Lookup: Go

Home

About

Learn

Access Content

Community

Search

CWE-190: Integer Overflow or Wraparound

Weakness ID: 190

Vulnerability Mapping: ALLOWED

Abstraction: Base

View customized information:

Conceptual

Operational

Mapping Friendly

Complete

Custom

Description

The product performs a calculation that can produce an integer overflow or wraparound when the logic assumes that the resulting value will always be larger than the original value. This occurs when an integer value is incremented to a value that is too large to store in the associated representation. When this occurs, the value may become a very small or negative number.

X + Y should be greater than X and Y

99

9

9

999 + 1

00

0

0

FIGURE 10: CWE-190 DESCRIPTION.

25

CVE

AboutPartner InformationProgram OrganizationDownloadsResources & Support

CVE-2025-58767

Search

Search tips | Provide feedback

Report/Request

Site Search

Notice: Expanded keyword searching of CVE Records (with limitations) is now available in the search box above. Learn more here

CVE-2025-58767

PUBLISHED

View JSON | User Guide

Collapse all

Required CVE Record Information

CNA: GitHub (maintainer security advisories)

Published: 2025-09-17 Updated: 2025-09-17

Title: REXML has a DoS condition when parsing malformed XML file

Description

REXML is an XML toolkit for Ruby. The REXML gems from 3.3.3 to 3.4.1 has a DoS vulnerability when parsing XML containing multiple XML declarations. If you need to parse untrusted XMLs, you may be impacted to these vulnerabilities. The REXML gem 3.4.2 or later include the patches to fix these vulnerabilities.

CWE 1 Total

Learn more

CWE-400: CWE-400: Uncontrolled Resource Consumption

CVSS 1 Total

Learn more

Score	Severity	Version	Vector String
1.2	LOW	4.0	CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N/E:U

Product Status

Learn more

Vendor	Product
ruby	rexml

On This Page

Required CVE Record Information

CNA: GitHub (Maintainer Security Advisories)

Authorized Data Publishers

CISA ADP

FIGURE 11: CVE-2025-58767 DESCRIPTION.

CWE

Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE

Start here!

Home > CWE List > CWE-400: Uncontrolled Resource Consumption (4.18)

ID Lookup:

Home | About | Learn | Access Content | Community | Search

CWE-400: Uncontrolled Resource Consumption

Weakness ID: 400

Vulnerability Mapping: DISCOURAGED

Abstraction: Class

View customized information:

Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not properly control the allocation and maintenance of a limited resource.

Give me all the books

Give me a book on CWE

Sorry! That book isn't on the shelf

FIGURE 12: CWE-400 DESCRIPTION

CVE

AboutPartner InformationProgram OrganizationDownloadsResources & Support

CVE-2025-61984

Search

Search tips | Provide feedback

Site Search

Notice: Expanded keyword searching of CVE Records (with limitations) is now available in the search box above. Learn more

CVE-2025-61984

PUBLISHED

View JSON | User Guide

Collapse all

Required CVE Record Information

CNA: MITRE Corporation

Published: 2025-10-06 Updated: 2025-10-06

Description

ssh in OpenSSH before 10.1 allows control characters in usernames that originate from certain possibly untrusted sources, potentially leading to code execution when a ProxyCommand is used. The untrusted sources are the command line and %-sequence expansion of a configuration file. (A configuration file that provides a complete literal username is not categorized as an untrusted source.)

CWE 1 Total

Learn more

CWE-159: CWE-159 Improper Handling of Invalid Use of Special Elements

CVSS 1 Total

Learn more

Score	Severity	Version	Vector String
3.6	LOW	3.1	CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N

Product Status

Learn more

Vendor	Product
OpenBSD	OpenSSH

On This Page

Required CVE Record Information

CNA: MITRE Corporation

CVE Program

Authorized Data Publishers

CISA-ADP

FIGURE 13: CVE-2025-61984 DESCRIPTION

CWE

Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE? Start here!

Home > CWE List > CWE-159: Improper Handling of Invalid Use of Special Elements (4.18)

ID Lookup: Go

Home | About | Learn | Access Content | Community | Search

CWE-159: Improper Handling of Invalid Use of Special Elements

Weakness ID: 159

Vulnerability Mapping: ALLOWED (with careful review of mapping notes)

Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not properly filter, remove, quote, or otherwise manage the invalid use of special elements in user-controlled input, which could cause adverse effect on its behavior and integrity.

Common Consequences

Impact

Details

Unexpected State

Scope: Integrity

Potential Mitigations

FIGURE 14: CWE-159 DESCRIPTION.

3.3 | Task-3: CVSS Scoring.

CVSSv4 Metric used for the calculation:

TABLE 19: CVSS VERSION 4 BASE METRIC SCORING(COMMON VULNERABILITY SCORING SYSTEM VERSION 4.0 CALCULATOR, NO DATE).

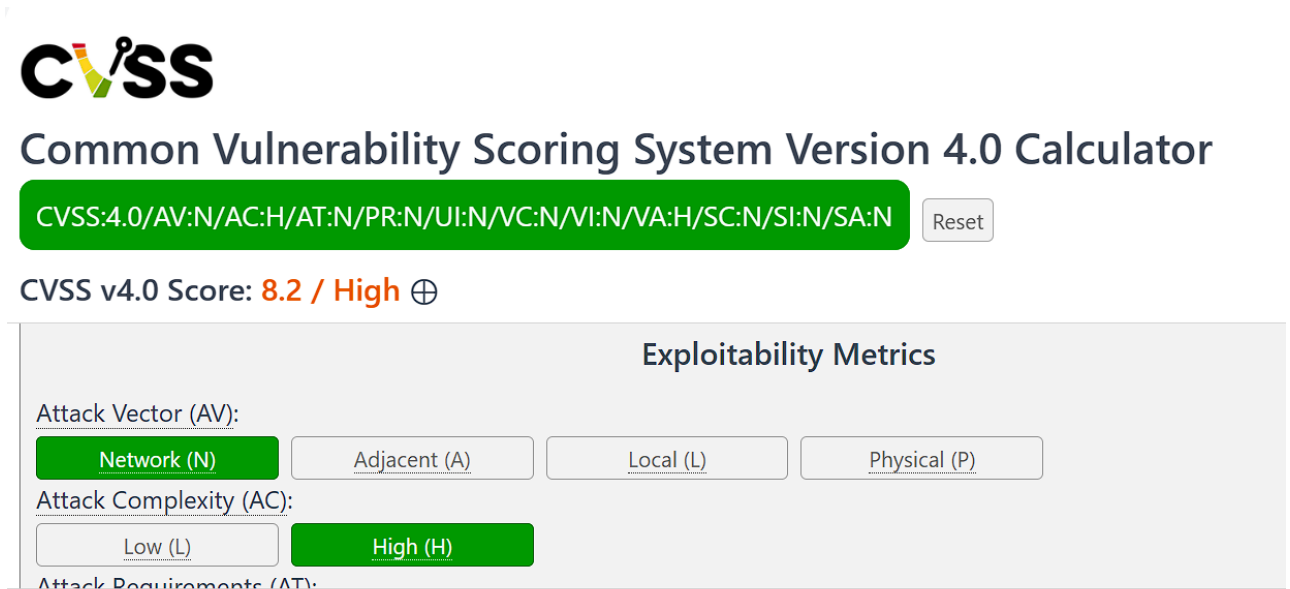
Metric	Meaning	What it Measures	Values
AV	Attack Vector	How attacker reaches system	Network(N), Adjacent(A), Local(L), Physical(P)
AC	Attack Complexity	Conditions required	Low, High
AT	Attack Requirements	Extra post-access requirements	None, Present
PR	Privileges Required	Attacker's privileges	None, Low, High
UI	User Interaction	Is a user action required?	None, Passive, Active
VC	Confidentiality (vulnerable)	Data exposure on vulnerable system	High, Low
VI	Integrity (vulnerable)	Data/system manipulation	High, Low , None
VA	Availability (vulnerable)	Service downtime/DoS	High, Low, None
SC	Confidentiality (subsequent)	Data exposure in downstream system	High, Low, None
SI	Integrity (subsequent)	Manipulation in downstream system	High, Low, None
SA	Availability (subsequent)	Downtime in downstream system	High, Low, None

- **CVE-2025-62171:**

CVSSv4 Vector: CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N

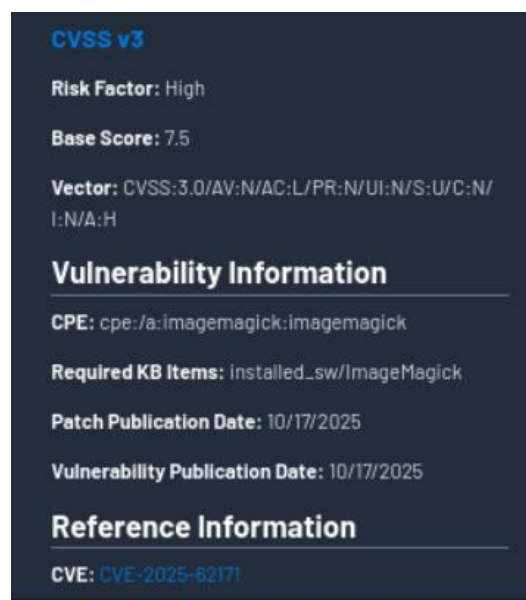
(from analyzing the vulnerability and using the CVSS base metric above)

CVSSv4 Score: 8.2



The image shows the CVSS Calculator interface. At the top is the CVSS logo. Below it is the title 'Common Vulnerability Scoring System Version 4.0 Calculator'. A green bar contains the vector 'CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N' and a 'Reset' button. Below this, the score is displayed as 'CVSS v4.0 Score: 8.2 / High' with a plus-minus icon. The main section is titled 'Exploitability Metrics' and contains three rows of buttons: 'Attack Vector (AV):' with 'Network (N)' (selected), 'Adjacent (A)', 'Local (L)', and 'Physical (P)'; 'Attack Complexity (AC):' with 'Low (L)' and 'High (H)' (selected); and 'Attack Requirements (AR):' (partially visible).

FIGURE 15: CVE-2025-62171 CVSS V4 SCORE.



The image shows a screenshot of the Nessus interface for CVE-2025-62171. It displays the following information:

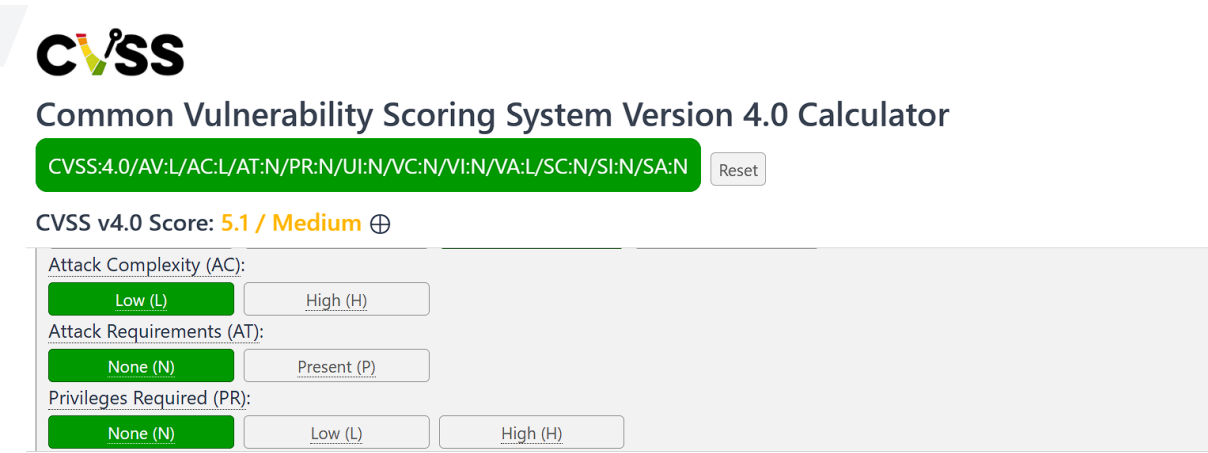
- CVSS v3**
- Risk Factor:** High
- Base Score:** 7.5
- Vector:** CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
- Vulnerability Information**
- CPE:** cpe:/a:imagemagick:imagemagick
- Required KB Items:** installed_sw/ImageMagick
- Patch Publication Date:** 10/17/2025
- Vulnerability Publication Date:** 10/17/2025
- Reference Information**
- CVE:** CVE-2025-62171

FIGURE 16: CVE-2025-62171 NESSUS SCORE.

- CVE-2025-58767

CVSSv4 Vector: CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N

CVSSv4 score (base vector): 5.1



CVSS
Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N Reset

CVSS v4.0 Score: **5.1 / Medium** ⊕

Attack Complexity (AC):

Attack Requirements (AT):

Privileges Required (PR):

FIGURE 17: CVE-2025-58767 CVSS V4 SCORE.



CVSS Score Source: CVE-2025-58767

CVSS v3

Risk Factor: Medium

Base Score: 5.3

Temporal Score: 4.6

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Temporal Vector: CVSS:3.0/E:U/RL:0/RC:C

CVSS v4

Risk Factor: Medium

Base Score: 5.1

Threat Score: 1.2

Threat Vector: CVSS:4.0/E:U

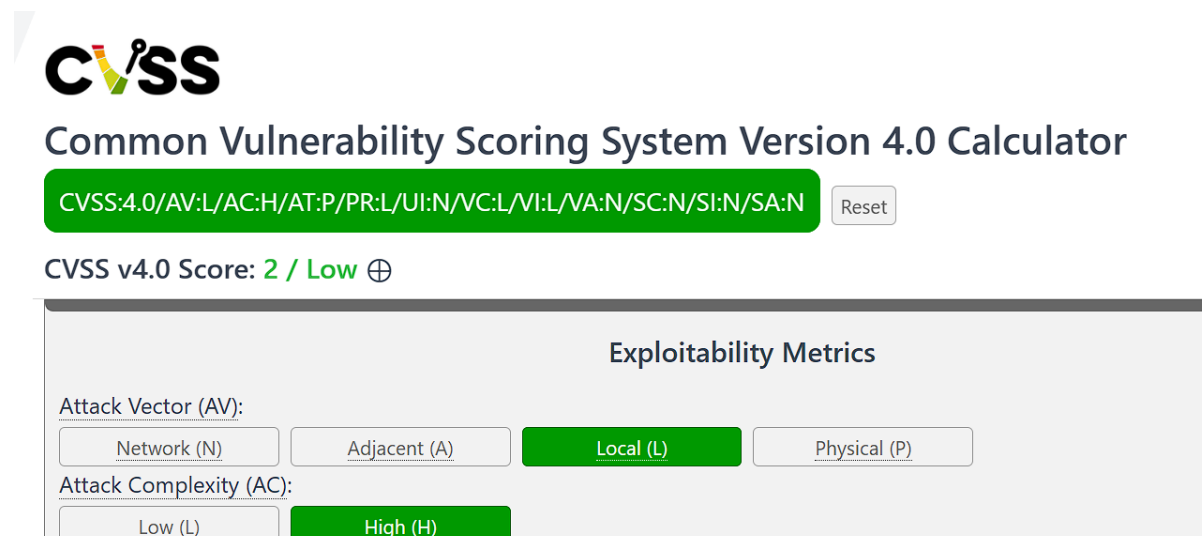
Vector: CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N

FIGURE 18: CVE-2025-58767 NESSUS SCORE.

- CVE-2025-61984

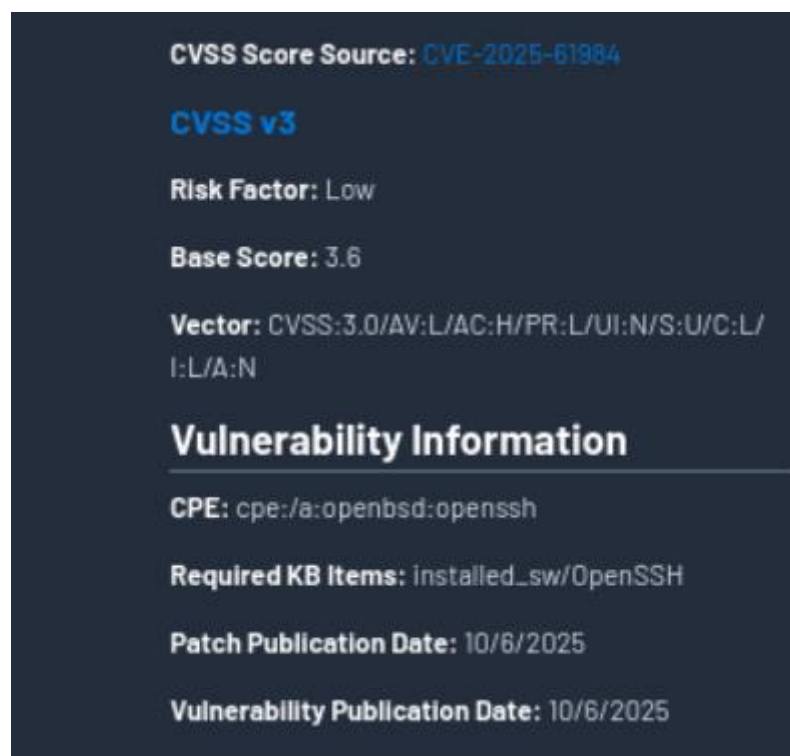
CVSSv4 Vector: CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

CVSSv4 Score: 2



The image shows the CVSS Calculator interface. At the top is the CVSS logo. Below it is the title 'Common Vulnerability Scoring System Version 4.0 Calculator'. A green bar displays the vector 'CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N' and a 'Reset' button. Below this, the score is shown as 'CVSS v4.0 Score: 2 / Low'. The 'Exploitability Metrics' section contains two rows of buttons. The first row is for 'Attack Vector (AV)' with options: Network (N), Adjacent (A), Local (L) (selected), and Physical (P). The second row is for 'Attack Complexity (AC)' with options: Low (L) and High (H) (selected).

FIGURE 19: CVE-2025-61984 CVSS V4 SCORE.



The image shows a dark-themed Nessus score card. It displays the 'CVSS Score Source' as 'CVE-2025-61984'. Below this is the 'CVSS v3' section, which shows a 'Risk Factor: Low' and a 'Base Score: 3.6'. The 'Vector' is listed as 'CVSS:3.0/AV:L/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N'. The 'Vulnerability Information' section includes the 'CPE: cpe:/a:openbsd:openssh', 'Required KB Items: installed_sw/OpenSSH', 'Patch Publication Date: 10/6/2025', and 'Vulnerability Publication Date: 10/6/2025'.

FIGURE 20: CVE-2025-61984 NESSUS SCORE.

Comparing scores:

TABLE 20: CVE-2025-62171 SCORE COMPARISON.

Version	Vector	Score	Comparison
Nessus (CVSSv3)	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7.5	CVSSv4 score is higher because v4 treats remote, no-privilege, no-interaction vulnerabilities especially DoS more serious than CVSSv3. Which replicates real world scenarios. Also, the removal of the scope metric and the addition of the AT metrics changed the weights of the score in CVSSv4.
CVSSv4	AV:N/AC:H/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N	8.2	

TABLE 21: CVE-2025-58767 SCORE COMPARISON.

Version	Vector	Score	Comparison
Nessus (CVSSv3)	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L	5.5	The CVSSv4 Base score is lower mainly because the Attack Vector is reassessed from Network to Local, and v4's scoring formula gives slightly less weight to low-impact DoS conditions. Also, the removal of the scope metric and the addition of the AT metrics changed the weights of the score in CVSSv4.
CVSSv4	AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N	5.1	

TABLE 22: CVE-2025-61984 SCORE COMPARISON.

Version	Vector	Score	Comparison
Nessus (CVSSv3)	AV:L/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N	3.6	The removal of the scope metric and the addition of the AT metrics changed the weights of the score in CVSSv4 reducing the score. Proxy command being local and configured in an unsafe way. The lower score actually reflects real world exposure.
CVSSv4	CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	2	

3.4 | Task-4: KEV Prioritization

TABLE 23: KEV PRIORITIZATION TABLE.

KEV	CRITICALITY	CVE	CVE (Root Cause)
No Results Found	High	CVE-2025-62171	CWE-190
No Results Found	Medium	CVE-2025-58767	CWE-400
No Results Found	Low	CVE-2025-61984	CWE-159

At the moment, none of the vulnerabilities above appear in the CISA KEV catalogue, which indicates they are not known to be actively exploited or have not met the criteria required for inclusion at the time they were identified (*Known Exploited Vulnerabilities Catalog* | CISA, no date).

Ranking Vulnerabilities according to patching priority order, determining what vulnerabilities should be patched first based on the level of risks.

CVE-2025-61984 (Extreme Priority):

Even though its CVSSv4 score is low (2.0), it can lead to full remote code execution when SSH uses `ProxyCommand` with untrusted username input. The score is misleadingly low, If exploited, an attacker could gain persistent access and fully compromise the system, and because OpenSSH is a core, often internet-facing

service, the stakes are extremely high. It requires, this should be treated as critical and needs urgent fix despite its score

CVE-2025-58767 (High Priority):

This vulnerability is ranked second because it is easy for attackers to exploit and can quickly take down any Ruby application that processes XML. The attacker only needs to submit a malformed XML file, making the attack trivial and highly reliable. Any API, service, or system that parses user-supplied XML is at risk of outage or disruption, so patching should be treated with high priority

CVE-2025-62171 (Lower Priority):

(ImageMagick BMP integer overflow) is the lowest patching priority because it only affects 32-bit systems, which are rarely used in modern environments. Since this flaw has a very narrow attack surface and limited real-world impact, it can be handled as part of routine maintenance rather than urgent remediation. It can safely be patched during the next scheduled update cycle.

TABLE 24: VULNERABILITY PRIORITIZATION TABLE.

CVE	CWE (Root Cause)	CVSS (v 4.0)	KEV	Patch status/Priority
CVE-2025-61984	CWE-159	2 (Low)	No Result	Extreme
CVE-2025-58767	CWE-400	5.1 (Medium)	No Result	High
CVE-2025-62171	CWE-190	8.2 (High)	No Result	low

3.5 | Task-5: Resilience and Redundancy(Ross *et al.*, 2021).

Vulnerability	Redundancy Measures	Resilience Measures
CVE-2025-61984 (OpenSSH)	Use an out-of-band access method such as IPMI, serial console, or AWS Session Manager. This gives administrators a backup way to access systems even if SSH becomes compromised or has to be shut down, preventing complete loss of control.	Harden SSH configuration by sanitising usernames and restricting risky features like ProxyCommand. This stops malicious control characters from being interpreted as commands, blocking the attack path and reducing the chance of exploitation.
CVE-2025-58767 (REXML XML Parsing DoS)	Place the application behind a load balancer with multiple servers. If one instance crashes due to malicious XML, traffic automatically shifts to healthy nodes, keeping the service available and avoiding full downtime.	Filter and validate XML at the proxy or WAF layer. Blocking malformed XML before it reaches the parser prevents the infinite loop that causes high CPU usage, protecting the system from DoS attacks.
CVE-2025-62171: ImageMagick BMP Overflow (32-bit only))	Use a fallback image-processing service like GraphicsMagick or libvips. If ImageMagick crashes processing a malicious BMP file, the system switches to the alternative service, keeping image workflows uninterrupted.	Configure strict resource limits or disable BMP processing in policy.xml. This avoids triggering the vulnerable code path, preventing crashes from malicious image files and reducing exposure.

REFERENCES

Common Vulnerabilities and Exposures (CVEs) | Tenable® (no date). Available at: <https://www.tenable.com/cve> (Accessed: December 5, 2025).

Common Vulnerability Scoring System Version 4.0 Calculator (no date). Available at: <https://www.first.org/cvss/calculator/4-0> (Accessed: December 5, 2025).

CWE - Common Weakness Enumeration (no date). Available at: <https://cwe.mitre.org/> (Accessed: December 5, 2025).

dvwa | Kali Linux Tools (no date). Available at: <https://www.kali.org/tools/dvwa/> (Accessed: December 5, 2025).

Known Exploited Vulnerabilities Catalog | CISA (no date). Available at: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (Accessed: December 5, 2025).

Ross, R. *et al.* (2021) "Developing cyber-resilient systems :". Available at: <https://doi.org/10.6028/NIST.SP.800-160V2R1>.

Shostack, A. (no date) "Threat Modeling."